

Cyber Insurance & Third-Party Risk

Cyber insurance reality

Covers: incident response, forensics, ransomware response (extortion), legal, notification costs, business interruption, liability

Does NOT cover: everything – warfare acts, pre-existing, negligence gaps

Premium conditions: insurers REQUIRE basics (MFA, backups, EDR, patching, response plan). Your posture literally prices your premium.

The smart contract angle

Policy review: what's explicitly included, cyber-extortion vs ransomware, sub-limits

Prove your controls (insurance audits your maturity)

Underwriters now ask: MFA on VPN? backup iso? incident response retained?

Third-party risk (vendor risk management)

Supply chain risk: you're only as secure as your vendors with your data.

Vendor questionnaire (SOC 2, ISO 27001, NIST CSF)

- > risk-tier (critical for access to PII/financial)
- > continuous monitoring (breach disclosure, security posture changes)
- > contract: liability, breach-notification terms, audit rights
- > exit clause (data return/deletion)

The VRM flow

Assessment: questionnaire + evidence (SOC2/ISO certs, pen test results)

Tier: critical (PII, financials) vs normal

Mitigate: require controls in contract; retest high tiers yearly

Monitor: news/watchlists (breach disclosure alerts), reassess posture

Offboard: data deletion, credential revocation, access removal

The big-brain question

"Who has my data?" – answer from an asset inventory + class/subclass registry, not from memory. Third-party risk fails when nobody keeps the list.

Insurance is risk transfer with strings attached – your controls set the price and the coverage. Vendor risk = auditing the parts of your perimeter you didn't build.

[← Disaster Recovery & Business...](#)

[Threat Modeling & Risk in Prac...](#)